COM521 Ethical Hacking and Pen testing – Labs

CEH v12 Module 13: Hacking Web Servers

The Importance of Web Server Security

"A single vulnerability in a web server's configuration can lead to a significant security breach. Ensuring strong security configurations is essential for protecting an organization's operations and reputation."

- **Key Attack Types:**
  - Denial of Service (DoS) and Distributed DoS (DDoS)
  - DNS Hijacking & Amplification
  - Directory Traversal
  - Man-in-the-Middle (MITM) & Sniffing
  - Phishing & Website Defacement
  - Web Server Misconfiguration
  - HTTP Response Splitting & Cache Poisoning
  - SSH Brute Force & Password Cracking

The Role of SSL/TLS and Trusted Co-Servers in Web Security

- Importance of SSL/TLS:
- SSL/TLS certificates provide a foundation of trust by enabling encrypted, authenticated connections. However, encryption alone cannot guarantee what happens on the server-side. Trusted third-party systems enhance this trust
- Introduction to Trusted Co-Servers:
- A security application with trusted co-servers uses secure co-processors and a guardian program to ensure server integrity. These co-servers act as a trusted third party in browser-server communication, creating an additional layer of assurance for web users.

Objectives

- Footprint a web server using various information-gathering tools and inbuilt commands
- Enumerate web server information
- Crack remote passwords

Footprint the web server

1. Information gathering using Ghost Eye
2. Perform web server reconnaissance using Skipfish
3. Footprint a web server using the httprecon Tool
4. Footprint a web server using Netcat and Telnet
5. Enumerate web server information using Nmap Scripting Engine (NSE)
6. Uniscan web server fingerprinting in Parrot Security

-

Perform a web server attack

Crack FTP credentials using a Dictionary Attack

Task1: Information gathering using Ghost Eye

- Launch Ghosteye using python 3
- Run option 3. Whois to perform fingerprinting
- Observe the information such as :

Domain Name, Registry Domain ID, Registrar WHOIS Server, Registrar URL, and Updated Date.

- Run option 2 to perform a DNS lookup
- Challenges - explore other functions of the application
- Investigate the python code to see how it is written
- Extract the code to get the headers configured from the webserver
  See Example on Solent Online learning tab Hacking Webservers

Task 2 : Skipfish

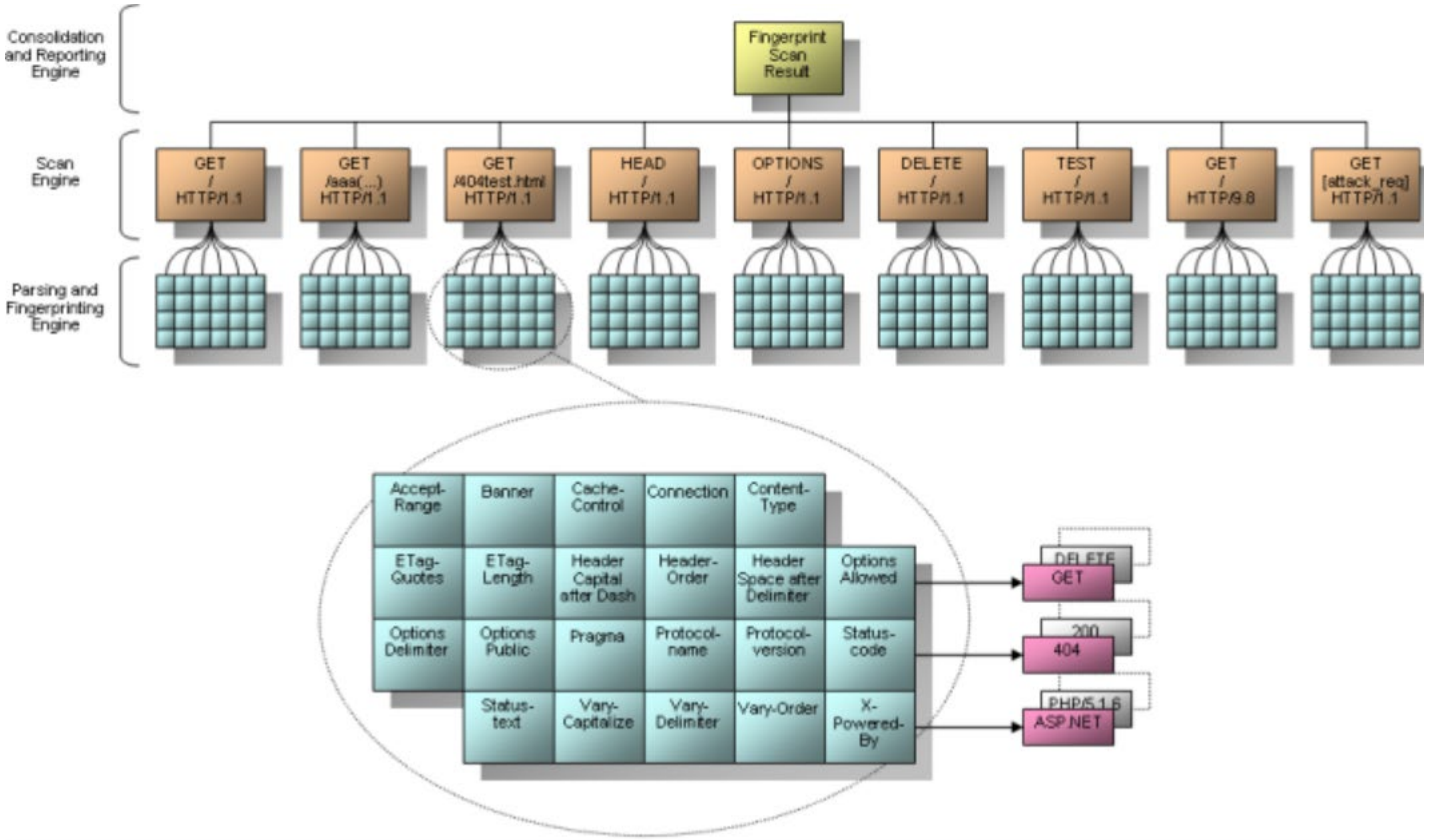
Skipfish is an active web application, security reconnaissance tool.

It prepares an interactive sitemap for the targeted site by carrying out a recursive crawl and dictionary-based probes.

- Run WAMP server on windows 2022
- Perform a bruteforce attack on the webserver using the following command:
- **skipfish -o /home/attacker/test -S /usr/share/skipfish/dictionaries/complete.wl http://[IP Address of Windows Server 2022]:8080**
- Skipfish scans the web server
- Skipfish generates a report
- The Skipfish crawl result appears in the web browser

Footprint a Web Server using the httprecon Tool

httprecon is a tool for advanced web server fingerprinting. This tool performs banner-grabbing attacks, status code enumeration, and header ordering analysis on its target web server.



Task 3 : HTTPRECON

Run httprecon on windows 11

Observe the server (**nginx**) used to develop the webpages.

Select GET long request tab, which lists all GET requests.

•

Task 4: Footprint a Web Server using Netcat and Telnet

Netcat is a networking utility that reads and writes data across network connections, using the TCP/IP protocol. It is a reliable “back-end” tool used directly or driven by other programs and scripts. It is also a network debugging and exploration tool.

- Use Netcat in Parrot Linux to open a port
- **nc -vv www.moviescope.com 80**
- type **GET / HTTP/1.0 to perform banner grabbing**
- **Telnet performs a similar process**
- **telnet www.moviescope.com 80**

Task 5: Enumerate Web Server Information using Nmap Scripting Engine (NSE)

- Nmap, along with Nmap Scripting Engine, can extract a lot of valuable information from the target web server. In addition to Nmap commands, Nmap Scripting Engine (NSE)provides scripts that reveal various useful information about the target web server to an attacker.
-

Enumerate Web Server Information using Nmap Scripting Engine (NSE)

- Enumerate the directories used by web servers and web applications
- **nmap -sV --script=http-enum [target website]**
- discover the hostnames that resolve the targeted domain.
- **nmap --script hostmap-bfk -script-args hostmap-bfk.prefix=hostmap- www.goodshopping.com**
- HTTP trace on the targeted domain
- **nmap --script http-trace -d www.goodshopping.com**

Enumerate Web Server Information using Nmap Scripting Engine (NSE)

- check whether Web Application Firewall is configured on the target host or domain:
- **nmap -p80 --script http-waf-detect www.goodshopping.com**

Task 6: Uniscan Web Server Fingerprinting in Parrot Security

Uniscan is a versatile server fingerprinting tool that not only performs simple commands like ping, traceroute, and nslookup, but also does static, dynamic, and stress checks on a web server.

Task 6: Uniscan Web Server Fingerprinting in Parrot Security

- Run the WAMP web server in windows 2022

1.uniscan -u http://10.10.1.22:8080/CEH -q

start scanning for directories.

- run **uniscan -u http://10.10.1.22:8080/CEH -we**
- **to** enable the file check (**robots.txt** and **sitemap.xml** file).
- use the dynamic testing option
- **uniscan -u http://10.10.1.22:8080/CEH -d**

Lab 2: Perform a Web Server Attack

- Crack FTP credentials using a Dictionary Attack
- Compromise of a user account
- Secondary attacks from the website and website defacement
- Root access to other applications or servers
- Data tampering and data theft
- Damage to the company’s reputation

Hydra

Hydra is a parallelized login cracker which supports numerous protocols to attack. It is very fast and flexible, and new modules are easy to add.

This tool makes it possible for researchers and security consultants to show how easy it would be to gain unauthorized access to a system remotely.

Dictionary attack using hydra

- Use **nmap -p 21** to scan for open FTP port on windows 11
- Use Hydra to perform the brute force attack
- **hydra -L /home/attacker/Desktop/Wordlists/Usernames.txt -P /home/attacker/Desktop/Wordlists/Passwords.txt ftp://[IP Address of Windows 11]**